

Case1 Security Policies

Group:15

Oooverarching cyber security policy

Transaction policy

Objective:

Sell and purchases transactions of cryptocurrency require to be secured for the organization to maintain credibility for customers. Loss or degradation of transaction data is unacceptable.

Statement:

- All transactions shall be flagged for logging before being carried out. When the flag is technically approved, the transaction payload to be carried out. In case of transaction corruption, the flagging remains for verification, tracking and accountability purposes.
- Transaction's type shall be carried out by Public-Key-Hash (P2PKH) using a simple cryptographic key pair (public and private key).

Who is affected:

the product owner, system administrator(s), technical support staff and customers.

Access Control policy

Objective:

The main objective of access control policy is to assure successfully authenticated entities and provided access to the right resources to the right person.

Statement:

To obtain an effective AC Policy, the company should check every access and, if needed, enforce the least privilege as well as verify acceptable usage. All subjects seeking to access resources shall be subject to strict access control mechanisms in order to enforce the principle of least privilege.

Who is affected:

Any entity/subject seeks to access resources.

Compliance policy

Objective:

The primary objective of demonstrating compliance is to ensure that legal liabilities are being satisfied.

Statement:

- Comply to regulations corresponding to type of data - All the applicable regulations with respect to the type of data being processed, handled and stores shall be followed to maintain continuous compliance.
- Comply with regulations corresponding to jurisdiction (i.e., EU, Swedish regulations)- All the applicable national and EU regulations shall be followed in order to maintain continuous compliance.
- Comply to ISO 27001 by managing ISMS - The most recent version of the international standard ISO 27001 shall be complied to by implementing the requirements put forth by the standard.

Who is affected: The organization as an entity is subject to compliance to the external requirements set forth by the stakeholders.

Technical cyber security policy

Backup and restore policy

Objective:

The policy's objective is to demonstrate the handling of Backup and restoration modes and control mechanisms that shall be implemented to ensure that essential data from day-to-day business is backed up securely, according to ISO 27002 paragraph 12.

“A backup policy should be established to define the organization’s requirements for backup of information, software and systems. The backup policy should define the retention and protection requirements. Adequate backup facilities should be provided to ensure that all essential information and software can be recovered following a disaster or media failure.” (ISO/IEC FDIS 27002:2013(E), paragraph 12.3.1)

Control mechanisms:

- **Accurate and complete**

The backups require to be accurate and complete; to ensure this, regularly test is essential.

- **Regularly tested**

The backups require to be tested regularly to ensure that they work accurately when needed and that the integrity holds up. Backups shall also be tested using hash algorithms, hashing the data before backup and after backup and comparing the hash values to ensure they are the exact same.

- **Restore to test environment**

Restored data should first be examined in a test environment and not quickly overwrite the currently operating databases in case of any error.

- **Securely encrypted backups**

The organisation need to store the private keys for the bitcoin wallet of the customers. These need to be appropriately encrypted, not to be accessed except for when the restoration is needed.

- **3-2-1 backup rule**

The organisation needs to grasp the 3-2-1 backup rule. This backup policy supports three copies of data (production data and two backup copies) in separate locations for emergency recovery.

- **Remote location**

To avoid having a single point of failure in a system, the backups need to be stored in a remote location.

- **Frequency of backups**

The backups should be executed once per day at the end of the day to make sure that critical transaction data is not lost.

- **Physical and environmental protection**

The backup equipment need to be physically secured against threats such as potential environmental disasters(earthquake), fires and floods as well as burglary.